IS - Apple Case Study

Question 1: If a “backdoor” is created:

a. How do you prevent misuse?

Answer:

Misuse prevention is very hard once a backdoor exists. Once GovtOS is compiled and tested the problem shifts from technical to operational, and operational security is a losing game. Keys get stolen, employees change, administrations change and legal frameworks degrade or get reinterpreted as we've seen in most historical cases.
The FBI's ask for a phone that is self destructing was technically not feasible. You cannot cryptographically bind code to a single device. Device specific checks are software conditions, patchable by anyone with root level access, same as the tool's authors. The only architecture that could possibly enforce device binding is a hardware root on every target which just creates a new attack surface.

The scope problem was visible in real time as more than 1300 other devices were queued up before Apple refused. One time would never have worked. If you're forced to design controls, the options are HSMs with multiparty authorization for key custody, air-gapped execution, cryptographic audit trails with strict chain of custody and case-specific clauses.

The Greece case study shows us these problems well. A lawful interception backdoor built into national telephone infrastructure got turned against the Greek parliament itself. The controls that were supposed to prevent exactly that kind of abuse failed. That's not an argument for better controls but an argument for not building the thing.

b. Can it be limited to one device?

Answer:

The FBI’s ask for one device only backdoor or access was technologically wrong and would not hold easily in practice. What GovtOS actually required was disabling auto erase, removing PIN attempt throttling, and enabling bruteforce input over USB or Bluetooth. None of those modifications are device specific at the firmware level. A modified iOS image that strips these protections is just a modified iOS image. Sign it with Apple's code signing key, which Apple holds, and it will sideload onto any device that trusts Apple's signature which is all apple devices.

The mechanism that could theoretically constrain this is the device UID which is the hardware identifier burned at manufacture. The Secure Enclave does use it for key derivation which is PIN plus UID produces the 256-bit AES key that protects user data. But the UID gates encryption, not execution. A firmware image that disables security features doesn't need to decrypt anything, it just needs to run. You could write an ECID check into GovtOS. It applies modifications only if the device identifier matches Farook's phone. That's a software branch that a reverse engineer could code in a day. This would make a small change but give a huge attack surface for attackers.

The iCloud analogy of the FBI makes the problem stronger. iCloud assistance would mean that Apple would be querying its servers with its own keys. And this would be done completely from within Apple's infrastructure. GovtOS is a portable tool that weakens device security. It exists outside that infrastructure once deployed. These can't be compared and using one to justify the other is misleading.

c. **What are the attack surfaces?**
   Answer:

There isn't just one attack surface from a backdoor. Instead small and distinct ones are created. These vulnerabilities add up very quickly. The tool itself is a high value target and the biggest vulnerability. GovtOS is the binary, source and signing infrastructure. It becomes something that every state actor, ransomware group, and organized crime will want to get. Any master access key needs the keys to be generated, stored, transported and protected. This is done such that there is one for each device sold. This is how the entire supply chain gets exposed. The security that Apple has to maintain would be very high compared to anything it currently operates and maintains.

Apple's code signing keys are a separate problem altogether. They make the ios firmware trusted by devices. Using them to sign GovtOS increases the exposure for the most sensitive cryptographic things that Apple holds. If the keys leak every iphone produced is a target and not just Farook's phone. The insider threat follows similarly. Every Apple employee with access to the tool, its source, or the signing process becomes a recruitment target for bribery or social engineering. Organizations with sensitive key material routinely get compromised this way.

Once the US establishes that Apple builds government access tools, every other jurisdiction that Apple operates in gets to cite it. China had already started demanding source code access and security audits before this case. A compliant GovtOS removes the basis for refusing the next government. Metadata and procedural templates are their own exposure category. Using GovtOS generates logs, legal records and repeatable workflows, which become the blueprint that reduces the threshold for every subsequent order.

The effaceable storage point is thought about the least. The 10 attempt wipe doesn't just overwrite data. It also deletes the encryption key and renders the underlying data unreadable permanently. GovtOS prevents that wipe. This means that any device that the tool is deployed against retains data that should have been irretrievable. Misuse doesn't just expose the target device going forward. It exposes everything already on it.

Question 2: **List your assets, adversaries and abuse cases.**

Answer:

Assets:
The stake here falls into two categories:

1) GovtOS itself as a script, Apple's code signing keys, Secure Enclave and its hardware UID, the encrypted user data on the device and the framework to check how lawful access requests get authorized.
2) Apple's reputation as a privacy respecting company and the iphone's entire market position is built on credible security guarantees which once removed, degrades their product.

Adversaries:
Countries are the most capable adversaries, China, Russia and Iran have clear motivation to be an adversary here. An iPhone bypass tool is very useful to countries surveilling journalists, dissidents and political opponents. China's existing pressure on Apple demanding security audits and local icloud key storage shows this threat.

Criminal organizations are also working to bypass the world's most widely deployed encrypted device as a tier one black market asset. These groups would treat obtaining it as a primary mission and exploit all possible vulnerabilities. Rogue insiders are also inevitable as the more people who touch the tool or the signing keys, the larger the bribery surface would be.

Other governments using legal instruments don't fit neatly into the adversary category, but their demands become an attack vector the moment US precedent is set. Apple then loses the legal basis to refuse a demand from the UK, India, or China after complying with the US government.

Primary Abuse Case:
A hostile government or criminal organization can obtain GovtOS through theft, insider compromise or legal compulsion after US precedent normalizes it. They can use it against devices of journalists, activists, lawyers or opposition leaders. Encrypted communications, location history, photos and behavioral data all of it becomes accessible. The Greece case is a very good example of this. The controls designed to prevent that exact outcome failed completely.

Secondary Abuse Case:
Domestic scope creep is slower but inevitable as once the legal framework exists and the tool is operational US law applies it beyond terrorism to whatever the current authority covers. A 4 digit PIN with no attempt delay and no wipe protection would fail immediately and the question would stop being whether to unlock a terrorist's phone in an extraordinary circumstance and would become whether any locked phone can be treated as unlockable.

Question 3: **Create a threat model for the “backdoor” using STRIDE.**
Answer: STRIDE Analysis:

Spoofing:
The trust model for the firmware verification depends entirely on authenticity of the signing authority. Compromising it would lead to the entire chain collapsing. An attacker who has Apple's signing keys can make firmware that every iPhone sees as legitimate and trusted. At the operational level a malicious actor could impersonate Apple or a trusted engineer to trigger GovtOS against unauthorized devices without using a private key. Countries have shown willingness to go after certificate authorities already. This makes spoofing the main backdoor created risk to tackle.

Tampering:
GovtOS is tamperable at every layer as the code can be modified to remove the ECID check and the condition that limits execution to Farook's device, making it universally deployable on all iphones. Stolen signing keys let an attacker create tampered firmware that devices accept. The legal procedure is a separate tampering surface, if court orders and chain of custody records can be forged or manipulated to allow deployment outside the original intent.

Repudiation:
Without audit logs and non-repudiation mechanisms built in accountability becomes very hard. Law enforcement can deny unauthorized deployments and Apple engineers can deny any wrongdoing. No existing framework governs compelled software development like this which is why Apple's asked for a congressional commission to resolve the same.

Information Disclosure:

At a high level the target device data becomes accessible and at lower level metadata about the tool's existence can leak to bad actors who now know Apple can be compelled and forced to create backdoors. At another level the fact of compliance signals to other governments that Apple will comply to such demands in future too.

The content and metadata would be at risk. Communication patterns, timing, frequency, location data could be used to reconstruct relationships, health status and political associations. Metadata has been used to identify sources, map dissident networks and infer medical conditions.

Denial of Service:
GovtOS exists to preserve evidence but its failure is permanent, irrecoverable evidence destruction. The 10 attempt wipe works by deleting the encryption key stored in storage not the underlying data, the data becomes instantly and permanently unreadable. If GovtOS malfunctions and triggers the wipe it was designed to prevent the FBI loses the thing it sought a court order to obtain.

The secondary DoS vector runs in the opposite direction, if the tool leaks and gets weaponized, it can be used to remotely wipe targeted devices as an offensive capability. The same mechanism that was supposed to preserve one terrorist's data becomes a tool for destroying anyone's data on demand.

Elevation of Privilege:

The baseline before this case is that the government can force apple to produce data it holds. The baseline the FBI was asking to establish was that government can compel Apple to build capabilities it does not yet have such as to access data Apple was architecturally prevented from accessing. This is not an extension of authority but a shift. And once it exists in law it applies to all cases. Every new government, every new jurisdiction, every new request operates from this baseline from which there is no going back.

Tim Cook called this order the software equivalent of cancer. The description is technically precise, an access foothold the system was never designed to permit becomes normalized, spreads to adjacent contexts and avoids removal because the legal and operational structures built around it develop their own. Privilege escalation in software can be patched but an escalation embedded in law cannot.

References:

- McGee, H., Hsieh, N., & McAra, S. (2016, revised 2017). Apple: Privacy vs. Safety (A). Harvard Business School Case No. 9-316-069.
- McGee, H., Hsieh, N., & Schwalb, N. (2018). Apple: Privacy vs. Safety (B). Harvard Business School Case No. 9-318-079.
- Honnavalli, P., Kanwal, P., & Vinodha, V. (2024). Information security (UE23CS343BB6): Unit 4, Lecture 5: Apple: Safety vs. security. PESU Center for Information Security, Forensics and Cyber Resilience, PES University.
- Apple Inc. (n.d.). Government information requests. https://www.apple.com/in/privacy/government-information-requests/
- Westin, A. F. (1967). Privacy and freedom. Atheneum.
- Nissenbaum, H. (2010). Privacy in context: Technology, policy, and the integrity of social life. Stanford University Press.
- Solove, D. J. (2008). Understanding privacy. Harvard University Press.
- Calo, M. R. (2011). The boundaries of privacy harm. Indiana Law Journal, 86(3), 1131-1162.
- Claude (Anthropic): AI-assisted reasoning tool. Used to develop and test analytical arguments.